

External Security Assessment

Target domain: yornik.eu

Report date	2026-09-28
Assessment type	Non-intrusive external review (passive recon + safe HTTP/TLS checks)
Requested by	Domain owner (yornik@gmail.com)
Authorization	Owner-authorized assessment of an owned domain
Prepared with	Claude Code
Classification	Internal

NOTE: This report records the result of read-only, external observations only. The assessment did not run intrusive tests. It did not attempt exploitation, brute-force, denial of service or authentication bypass. Section 6 lists the tools and the procedure for the owner to run the intrusive phases in a controlled window.

1. Executive summary

This report covers an external security review of the domain yornik.eu. The review used passive reconnaissance and safe HTTP and TLS checks. The public posture of the web endpoint is strong.

The site enforces HTTPS. It uses TLS 1.3 with a valid certificate. It sets a strict Content-Security-Policy and HTTP Strict Transport Security with preload. It does not expose common sensitive paths such as `/.git/config` or `/.env`. It disables the TRACE method.

The review found no high or medium severity issue from the external surface. It found low and informational items. The main items are a wide subdomain inventory in `security.txt`, an incomplete DMARC policy, and a disclosed server version. Section 4 lists each item.

Findings by severity

Severity	Count
High	0
Medium	0
Low	4
Informational	3
Positive controls	6

2. Scope and authorization

The domain owner asked for this assessment of a domain that the owner controls. The scope is the public web endpoint of yornik.eu and its public DNS records.

In scope	yornik.eu (HTTPS endpoint), public DNS records for yornik.eu
Out of scope	Subdomains, third-party services (AWS SES, Cloudflare), any active attack
Method	Passive DNS-over-HTTPS queries, HTTP header inspection, TLS handshake inspection, read-only path checks
Limits	External view only. No credentials. No internal network access. No source code review.

3. Methodology

The assessment follows the reconnaissance and analysis phases of the Penetration Testing Execution Standard (PTES) and the OWASP Web Security Testing Guide (WSTG). This engagement ran the passive phases only. The intrusive phases are for the owner to run. See Section 6.

Phase	Standard reference	Run here?
1. Passive reconnaissance (DNS, WHOIS, certificates)	PTES Intelligence Gathering	Yes
2. Transport security review (TLS versions, ciphers, certificate)	OWASP WSTG-CRYP	Yes
3. HTTP configuration review (headers, methods, redirects)	OWASP WSTG-CONF	Yes
4. Information exposure review (well-known paths, metadata)	OWASP WSTG-INFO	Yes
5. Active scanning (open ports, service versions)	PTES Vulnerability Analysis	No (owner runs)
6. Web application testing (injection, auth, session)	OWASP WSTG-INPV, ATHN, SESS	No (owner runs)
7. Exploitation	PTES Exploitation	No (owner runs)

4. Findings

Each finding has a severity, the evidence and a recommendation. The severity uses the external impact of the item. It is not a CVSS score.

F-01	LOW	Wide subdomain inventory disclosed in security.txt
------	-----	--

Evidence. The file `/.well-known/security.txt` lists Canonical URLs for many subdomains. The list includes host names that suggest sensitive functions, such as `passwords.yornik.eu`, `secrets.yornik.eu`, `argocd.fedishark.eu` and `grafana.fedishark.eu`. This gives an attacker a map of the estate.

Recommendation. Keep only the canonical entries that a researcher needs. Move the full host list out of the public file. Make sure each named host enforces authentication and is not reachable without it.

F-02	LOW	DMARC policy has no reporting and no alignment tuning
------	-----	---

Evidence. The record is `v=DMARC1; p=quarantine;`. It has no `rua` aggregate report address. It has no `pct` and no alignment tags. Without reports the owner cannot see spoofing attempts or misconfiguration.

Recommendation. Add an `rua` address to receive aggregate reports. Confirm SPF and DKIM alignment. When the reports are clean, move the policy to `p=reject`.

F-03	LOW	No DKIM record at common selectors
------	-----	------------------------------------

Evidence. Queries for the selectors `default`, `google`, `selector1`, `selector2`, `mail` and `k1` returned no TXT record. The domain sends mail through Amazon SES (SPF include and MX). A custom selector can exist. If no DKIM signing is active, DMARC relies on SPF alone.

Recommendation. Confirm that Amazon SES DKIM signing is active with the SES-assigned selectors. Verify that outbound mail is DKIM-signed and aligned.

F-04	LOW	Web server version disclosed
------	-----	------------------------------

Evidence. The HTTP response sets `server: nginx/1.31.1`. The exact version helps an attacker match known issues to the server.

Recommendation. Set `server_tokens off;` in the nginx configuration to hide the version.

F-05	INFO	Deprecated X-XSS-Protection header set
------	------	--

Evidence. The response sets `x-xss-protection: 1; mode=block`. Modern browsers ignore this header. The Content-Security-Policy already gives stronger protection.

Recommendation. Remove the header. It has no effect and can cause side effects in old browsers. The strict CSP is the correct control.

F-06	INFO	DNSSEC state not confirmed from the external view
------	------	---

Evidence. The domain uses Cloudflare name servers. The passive checks did not confirm a signed zone. Without DNSSEC an attacker who can poison a resolver can redirect the name.

Recommendation. Confirm that DNSSEC is active for `yornik.eu` in the Cloudflare dashboard. Enable it if it is off.

F-07	INFO	SPF uses a soft fail
------	------	----------------------

Evidence. The SPF record ends with ~all (soft fail). A receiver can still accept mail that fails SPF. This is a common and acceptable setting, but a hard fail is stronger.

Recommendation. When DMARC reporting confirms all senders, change ~all to -all for a hard fail.

5. Controls that work well

The review confirmed these controls from the external view.

Control	Evidence
HTTPS enforced	http://yornik.eu returns 308 to the HTTPS URL.
HSTS with preload	strict-transport-security: max-age=31536000; includeSubDomains; preload
Modern TLS	TLS 1.3, cipher TLS_AES_128_GCM_SHA256, key exchange X25519, ECDSA P-384 certificate.
Valid certificate	CN=yornik.eu, issued by Let's Encrypt, valid to 2026-11-26, chain verified.
Strict CSP	default-src 'self'; object-src 'none'; frame-ancestors 'none'; no inline script allowed.
Clickjacking defence	x-frame-options: DENY and frame-ancestors 'none'.
No sensitive paths	/.git/config, /.env, /server-status, /wp-login.php return 404.
TRACE disabled	TRACE returns 405.
CAA records set	CAA limits certificate issuance to named authorities.
security.txt present	A PGP-signed /.well-known/security.txt gives a contact address.

6. How to run the intrusive phases

The owner can run the active phases against the owned hosts. Run them from a controlled network and inside a planned window. The list below is the standard tool set for each phase.

WARNING: An active scan can slow a service or trigger an alert. Run it in a maintenance window. Tell any hosting provider first if their terms require it.

Phase	Tool	Purpose
Port and service discovery	nmap	Map open TCP and UDP ports and service versions.
TLS deep check	testssl.sh, sslyze	List every protocol, cipher and certificate weakness.
HTTP header and posture	Mozilla Observatory, securityheaders.com	Grade the header configuration.
Web vulnerability scan	OWASP ZAP, Burp Suite	Crawl and test the application for common web flaws.
Template-based checks	nuclei	Run a large set of community checks for known issues.
Subdomain discovery	amass, subfinder	Find hosts that are reachable but not linked.
Directory and file discovery	ffuf, gobuster	Find hidden paths and backup files.
CMS checks (if used)	wpscan and similar	Test a content system for known issues.
DNS and email posture	dnsrecon, dmarcian, MXToolbox	Check DNSSEC, SPF, DKIM and DMARC.

Example commands for the owner to run against owned hosts

```
nmap -sS -sV -Pn -p- --min-rate 1000 yornik.eu
testssl.sh --full https://yornik.eu
nuclei -u https://yornik.eu -severity low,medium,high,critical
ffuf -u https://yornik.eu/FUZZ -w wordlist.txt -mc 200,301,302,401,403
subfinder -d yornik.eu | httpx -status-code -title
```

7. Prioritized recommendations

1. Confirm authentication on every host named in security.txt. Confirm that passwords.yornik.eu and secrets.yornik.eu are not reachable without login. (F-01)
2. Add DMARC aggregate reporting. Set an rua address. Move to p=reject when reports are clean. (F-02, F-07)
3. Confirm Amazon SES DKIM signing is active and aligned. (F-03)
4. Hide the nginx version with server_tokens off. (F-04)
5. Confirm DNSSEC is active in Cloudflare. (F-06)
6. Remove the deprecated X-XSS-Protection header. (F-05)
7. Run the active phases in Section 6 in a planned window. Record the result in a follow-up report.

8. Evidence appendix

The data below is the raw output that the findings use. Collected 2026-09-28.

HTTP response headers (<https://yornik.eu>)

```
HTTP/2 200
content-security-policy: default-src 'self'; base-uri 'self';
  frame-ancestors 'none'; form-action 'self'; object-src 'none';
  script-src 'self'; style-src 'self'; img-src 'self' data:;
  font-src 'self' data:; connect-src 'self'; upgrade-insecure-requests
strict-transport-security: max-age=31536000; includeSubDomains; preload
x-content-type-options: nosniff
x-frame-options: DENY
referrer-policy: no-referrer
x-xss-protection: 1; mode=block
server: nginx/1.31.1
```

TLS handshake

```
TLSv1.3 / TLS_AES_128_GCM_SHA256 / X25519
subject: CN=yornik.eu
issuer: C=US; O=Let's Encrypt; CN=YE2
expire date: Nov 26 10:48:40 2026 GMT
certificate key: EC secp384r1 (384 bit); verify: ok
```

DNS records (via DNS-over-HTTPS)

```
A/AAAA: 77.42.94.152, 78.47.240.158,
  2a01:4f8:1c19:60c2::1, 2a01:4f9:c014:e6de::1
MX: 10 inbound-smtp.eu-west-1.amazonaws.com.
NS: vick.ns.cloudflare.com. / michelle.ns.cloudflare.com.
TXT: v=spf1 include:amazonses.com ~all
_dmarc: v=DMARC1; p=quarantine;
CAA: issue letsencrypt.org / digicert.com / pki.goog / ssl.com / comodoca.com
```

Path checks (HTTP status)

```
404 /.git/config    404 /.env    404 /server-status
404 /admin          404 /wp-login.php
200 /robots.txt     200 /sitemap.xml    200 /.well-known/security.txt
```

End of report. This assessment reflects the external state on 2026-09-28. A change to the configuration after this date can change the result.